

CTI-2026-0510-LAZARUS-GITHOOKS

북한 Lazarus Group 의 새로운 은닉 기법 - .git/hooks/를 2 단 로더로 사용한 Contagious Interview·TaskJacker 캠페인

한국어 정식판 — TLP:GREEN

항목	내용
보고서 ID	CTI-2026-0510-LAZARUS-GITHOOKS
발행일	2026-05-10
TLP	TLP:GREEN
등급	
심각도	● HIGH — 한국 개발자·거래소·Web3 직접 표적
분류	Threat Actor Campaign / Supply Chain via Social Engineering / Developer Targeting
핵심 키워드	Lazarus Group, DPRK, Contagious Interview, TaskJacker, Famous Chollima, BeaverTail, InvisibleFerret, OtterCookie, git hooks, post-merge, post-checkout, MITRE G1052, fake recruiter
원문 출처	OpenSourceMalware.com, "Lazarus Group Uses Git Hooks To Hide Malware" (2026-05)
교차 검증	Microsoft Security Blog (2026-03), Abstract Security (2026-03), Cisco Talos (2025-10), Socket (2025-06~10), NVISO Labs (2025-11), Malpedia G1052
연관 보고서	CTI-2026-0507-SCARCRUFT (APT37, 별도 DPRK 클러스터) · CTI-2026-0422-MCP §3.3 (UNC1069/Sapphire Sleet 공급망 오염)
작성	Dennis Kim, https://github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT

1. 요약 (Executive Summary)

OpenSourceMalware 는 2026 년 5 월, 북한 Lazarus Group(MITRE ATT&CK G1052 — Contagious Interview / Famous Chollima)이 가짜 채용 캠페인의 2 단 로더(second-stage loader)를 **.git/hooks/ 디렉터리에 은닉하는** 새로운 변종을 공개했다.

이번 분석 결과 북한은 적극적으로 AI LLM 을 도입하여 탐지를 회피하고 목적에 맞는 언어와 플랫폼으로 전환을 실시간으로 하고 있다는 것을 알게 되었다.

핵심 판단 (Key Judgments)

#	판단	신뢰도
KJ-1	Lazarus 는 npm 패키지 → 가짜 화상회의 도구 → VS Code Tasks → git hooks 순으로 전달 메커니즘을 진화시키고 있다. 각 진화는 직전 변종에 대한 방어자 차단·완화 조치(Microsoft VS Code 1.109/1.110 패치, 2026-02)에 직접 대응한 것이다.	High
KJ-2	git hooks 는 .git/hooks/가 git 에 의해 추적되지 않기 때문에 , 코드 리뷰·PR diff 에 노출되지 않는 사각지대다. 일반 개발자가 clone 후 pull·merge 만 해도 코드 한 줄 실행하지 않은 채 감염된다.	High
KJ-3	1 차 표적은 블록체인·핀테크·국방 분야 개발자 이며, 한국 시장은 LinkedIn Korea 채용 활성화, DAXA 거래소·Web3 스타트업 밀집도, 외화 결제 가능 프리랜서 풀의 규모로 인해 글로벌 평균 대비 노출도가 높다 .	High
KJ-4	최종 페이로드(BeaverTail → InvisibleFerret)는 암호화폐 지갑(Solana, Exodus), 브라우저 자격증명, macOS 키체인 탈취 에 특화되어 있다. Lazarus 는 동일 인프라로 Bybit(\$14 억), Stake(\$4,100 만), CoinEx(\$2,700 만) 사고를 일으킨 전력이 있다.	High
KJ-5	이 사건의 진짜 위협은 단일 기법이 아니라, Lazarus 가 개발자 채용이라는 정서적·인지적으로 가드가 내려가는 순간을 무기화 한다는 점이다. 이는 기술적 통제만으로는 완전 차단이 불가능하다 — 개발자 OPSEC 교육과 격리 환경 의무화 가 동등한 위상의 통제 수단이다.	Medium-High

2. 사건 배경 (Background)

2.1 Contagious Interview 캠페인의 진화 궤적

시기	전달 메커니즘	핵심 사례	방어자 대응
2022 ~ 2024	npm 패키지 typosquatting	is-buffer-validator, yoojae-validator, event-handle-package, array-empty- validator, react-event-dependency, auth- validator 등	Socket-npm 신고 기반 제거
2024 ~ 2025 H1	가짜 화상회의 도구	"MiroTalk Studio" 등으로 위장한 macOS/Windows 바이너리	VirusTotal·EDR 시그니처
2025 H2	대규모 npm 캠페인	Socket 보고: 67 개 패키지(2025-06) → 338 개 패키지, 5 만 다운로드 (2025-10). XORIndex 로더 신종 공개	자동 패키지 스캔 강화
2026 Q1	VS Code / Cursor Tasks 악용	.vscode/tasks.json 의 자동 실행 속성 악용. C2: hxxp://144.172.115[.]189:8080	Microsoft VS Code 1.109(2026- 01)·1.110(2026-02)에서 자동 task 실행 기본값 OFF 로 변경
2026 Q2 (현재)	.git/hooks/ 은닉	OpenSourceMalware 2026-05 공개. post- merge, post-checkout, pre-push 혹은 BeaverTail 다운로드 삽입	(현시점 차단 메커니즘 부재)

각 진화는 직전 변종에 대한 차단 조치 직후 발생했다. 방어자가 한 통로를 막을 때마다 Lazarus 는 약 3~6 개월 안에 더 깊은 곳으로 옮겨가는 패턴을 보이고 있다.

북한의 해킹 능력은 뛰어나지 않지만 사회 공학적 해킹을 결합하여 Bybit, Upbit 와 같은 타겟팅된 해킹 공격에 능하다.

2.2 위협 행위자 식별 (Attribution)

본 캠페인은 다음 네이밍으로 트래킹되고 있다:

트래커	클러스터명
MITRE ATT&CK	G1052 — Contagious Interview
CrowdStrike	Famous Chollima
Microsoft	Sapphire Sleet (관련, 일부 중첩)
Mandiant	UNC4034 / DPRK CryptoCore (관련)
Lazarus 상위 그룹	(전통적 의미의) Lazarus Group, APT38

주의: Contagious Interview 는 Lazarus 의 모든 활동이 아니라 **개발자 채용 위장 작전** 전담 서브 클러스터다. APT37(ScarCruft), Kimsuky 등과 구분된다.

3. 공격 체인 분석 (Attack Chain)

3.1 5 단계 감염 흐름

[1] 정찰·접촉 → [2] 신뢰 구축 → [3] 코딩 과제 전달 → [4] git hook 트리거
→ [5] 영구 백도어

단계	행위	표적의 인지
1. 정찰·접촉	LinkedIn / 채용 플랫폼 / 프리랜서 사이트(Upwork, Fiverr 등)에서 표적 식별. AI 생성 프로필 사진을 사용한 가짜 리크루터 페르소나로 접근	“관심 있는 회사에서 연락이 왔다”
2. 신뢰 구축	정상적으로 보이는 회사 도메인(WHOIS 는 보통 수주~수개월), 영문 이메일, 다단계 인터뷰 절차 안내	“정식 절차다”
3. 코딩 과제 전달	GitHub / GitLab / Bitbucket 의 비공개 또는 ZIP 형태 리포지토리 전달. 표면상 평범한 React·Node·Python 과제	“코드 자체는 정상이다”
4. git hook	표적이 git clone, git pull, git merge, git checkout 등	무인지 — 대부분의

단계	행위	표적의 인지
트리거	일상적 명령 실행 시 .git/hooks/post-merge 또는 post-checkout 이 silent 실행되어 BeaverTail 다운로드	개발자는 .git/hooks/를 들여다보지 않는다
5. 영구 백도어	BeaverTail 이 InvisibleFerret(Python 백도어)을 설치, 자격증명·암호화폐 지갑 탈취 → C2 통신 → 영구 접근 확보	자연 인지 (수일~수주 후 자산 손실로 확인)

3.2 왜 git hooks 가 새로운 사각지대인가?

속성	설명
Git 추적 제외	.git/hooks/ 디렉터리는 .git/ 자체와 함께 git 이 추적하지 않는다. 즉 PR diff·코드 리뷰·git log 에 절대 나타나지 않는다
자동 실행	표적이 코드를 한 줄도 실행하지 않아도, 단순한 git pull 한 번으로 hook 이 자동 발화
권한 환경	hook 은 사용자 권한으로 실행되며 인터넷 접근, 파일 시스템 접근, 자식 프로세스 spawn 이 모두 가능
표면적 정상	리포지토리 자체의 코드(README, 소스 파일)는 진짜 정상일 수 있다. SAST·정적 분석 통과
개발자 무자각	신입~10 년차 이상 개발자도 .git/hooks/를 들여다보는 습관이 거의 없다. 도구 체인에 가려져 있다

본질 진단: git hooks 는 “Git 자체가 신뢰 경계의 일부로 취급되지만, 사용자가 그 내부를 보지 않는다”는 **신뢰 비대칭(trust asymmetry)**을 무기화한 사례다. SolarWinds·XZ Utils 가 빌드 시스템에 대해 한 일을, 본 캠페인은 **개인 개발자의 워크스테이션**에 대해 수행한다.

4. 주요 악성코드 분석

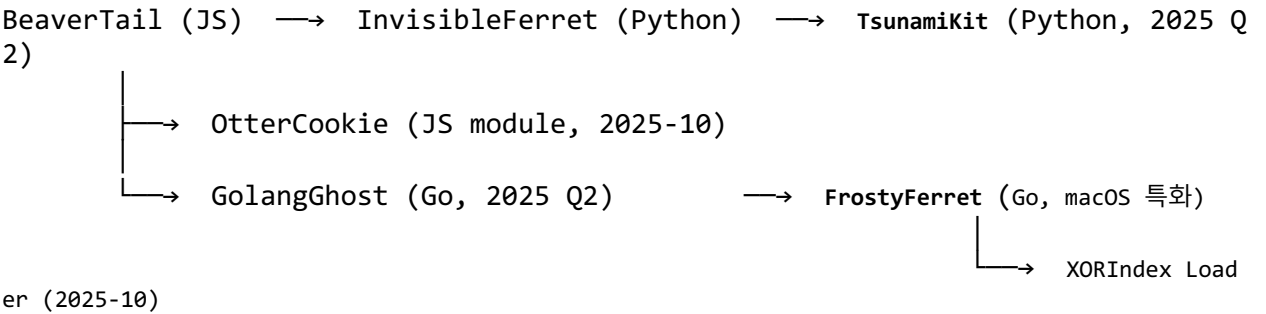
4.1 BeaverTail (1 차 페이로드)

항목	내용
언어/플랫폼	JavaScript (Node.js 환경)
역할	Infostealer + 2 차 페이로드(InvisibleFerret) 다운로더
표적 데이터	• 브라우저 자격증명 (Chrome, Brave, Firefox)• 암호화폐 지갑 (Solana CLI 키, Exodus, MetaMask)• macOS Keychain• SSH 키, AWS/GCP 자격증명
샌드박스 회피	qemu-virtual-parallels-virtualbox-vmware 키워드 검사
C2 통신	다수 IP 로테이션, HTTP POST 기반 exfiltration
변종	OtterCookie (2025-10 Cisco Talos 분석, JavaScript 모듈 추가)

4.2 InvisibleFerret (2 차 페이로드)

항목	내용
언어/플랫폼	Python (모든 OS)
역할	영구 백도어, RAT 기능, 추가 페이로드 stager
지속성	• Linux: cron + systemd user unit• macOS: LaunchAgent (~/.Library/LaunchAgents/)• Windows: Run 키 + Scheduled Task
변종	TsunamiKit (2025-04 HiSolutions), GolangGhost (2025-04 Silent Push, Go 포팅판)

4.3 도구 계보 (2025-2026)



이 소스 가지치기는 Lazarus 가 여러 언어 스택(JS, Python, Go)으로 동일 기능을 포팅하면서 EDR 탐지를 우회하는 표준 운영 패턴을 보여준다.

한 줄 요약: AI LLM 의 발전으로 북한도 탐지를 회피하기 위한 실시간 포팅이 늘어나고 있다.

5. 한국 환경 영향 평가 (Korean Impact Assessment)

5.1 한국 개발자가 글로벌 평균 대비 노출도가 높은 이유

요인	설명	위험 증폭
LinkedIn Korea 활성도	2025 년 기준 한국 LinkedIn 사용자 ~700 만 명, 개발자·블록체인 분야가 가장 활발한 활용 그룹 중 하나	1 차 접촉 채널이 풍부
DAXA 거래소·Web3 스타트업 밀집	5 대 원화 거래소(Upbit, Bithumb, Coinone, Korbit, Gopax) + DAXA 회원사 + 다수의 Web3 발행사 본사가 서울 집중	표적 가치가 높다
외화 결제 프리랜서 풀	Upwork·Fiverr·Toptal 에서 활동하는 한국 개발자 인구 증가 (특히 frontend, smart contract)	가짜 리크루터 접근이 자연스럽다
AI 코딩 도구 도입 가속	Cursor, Claude Code, Copilot 도입 기업 증가 → .vscode/tasks.json 변종 노출도 동반 상승	직전 변종도 여전히 유효
국방·방산 연구원 LinkedIn 활동	KAI·LIG 넥스원·한화 등 협력사 개발자가 LinkedIn 에서 채용 정보를 공개 검색	국가안보 차원 위협

5.2 시나리오별 위협 모델

시나리오	가능성	영향도	대응
			우선순위
S1. 거래소 백오피스 개발자가 가짜 인터뷰 후 자격증명 유출 → 거래소 내부 시스템 lateral movement	매우 높음	매우 높음	P0
S2. Web3 발행사 Solidity 개발자의 deploy 키·멀티시그 시드 유출 → 토큰 컨트랙트 owner 탈취	매우 높음	매우 높음	P0
S3. 프리랜서 개발자가 감염 → 다수 클라이언트 코드베이스에 백도어 잠복	높음	높음	P1

시나리오	가능성	영향도	대응 우선순위
S4. 방산 협력사 개발자 감염 → 비공개 무기체계 코드 일부 유출	중~높음	매우 높음	P0 (국가안보)
S5. AI 회사 ML 엔지니어 감염 → 모델 가중치·학습 데이터 유출	중간	높음	P1

5.3 역사적 손실 규모 (Lazarus 관련)

사건	시점	손실 규모
Bybit hack	2025	약 14 억 달러 (역대 최대 단일 거래소 사고)
Stake.com hack	2023	4,100 만 달러
CoinEx hack	2023	2,700 만 달러
Atomic Wallet	2023	1 억 달러+
누적 추정	2017~2026	30 억 달러+ (Chainalysis)

Lazarus의 주 수익원이 곧 **북한 정권의 핵·미사일 프로그램 자금원**이라는 것은 미 재무부·UN 패널 보고서를 통해 반복 확인된 사실이다. 따라서 본 캠페인 차단은 단순 보안 사안이 아니라 **국가 안보·국제 제재 이행 사안**이다.

6. IOC (Indicators of Compromise)

본 IOC 는 OpenSourceMalware, Microsoft, Cisco Talos, Abstract Security, Socket 의 공개 자료에서 교차 추출한 것이며, 실시간으로 변경된다. 운영 적용 전 반드시 최신 상태 재확인.

6.1 네트워크 IOC (대표값, 시점 기준)

유형	값	출처
C2 IP	144.172.115[.]189:8080	Abstract Security (2026-03)
페이로드 도메인	camdriver[.]pro (macOS WebCam.zip 다운로드)	Abstract Security (2026-03)
C2 패턴	HTTP POST 에 excludeFolders, scanDir 키워드 동반	Microsoft (2026-03)

6.2 호스트 IOC (행위 기반)

인디케이터	설명
.git/hooks/post-merge 또는 post-checkout 또는 pre-push 에 base64 인코딩 페이로드 또는 curl/wget 다운로드 호출	git hook 변종
~/Library/LaunchAgents/에 신규 plist 생성	macOS 지속성
~/.config/autostart/에 신규 .desktop 파일	Linux 지속성
Windows HKCU\Software\Microsoft\Windows\CurrentVersion\Run 에 신규 항목	Windows 지속성
node 프로세스가 qemu, vmware, parallels 키워드를 명령행에 포함	BeaverTail 샌드박스 회피
wscript.exe 가 PowerShell:CMD:temp 디렉터리에서 .vbs 실행	OtterCookie 변종
의심 파일명: WebCam.zip, WebCam/, update.dmg, MiroTalk*.zip	가짜 화상회의 도구 변종

6.3 행위 IOC (개발자 워크스테이션 헌팅)

패턴	의심 신호
git pull 또는 git merge 직후 1~10 초 내에 외부 도메인으로 outbound	hook 트리거 가능성
Node.js 프로세스가 clipboard + socket.io + axios 모듈 동시 임포트	BeaverTail 페이로드 시그니처
Python 이 requests + subprocess + base64 로 외부 호출 직후 자식 프로세스 spawn	InvisibleFerret 패턴

7. 탐지 룰 / 헌팅 쿼리 (Detection)

7.1 Microsoft Defender XDR (KQL — Microsoft 공개 룰 기반, 2026-03)

```
DeviceProcessEvents
| where (
    (InitiatingProcessCommandLine has_all ("axios", "const uid", "socket.io")
    and InitiatingProcessCommandLine contains "clipboard") or
    (InitiatingProcessCommandLine has_all ("excludeFolders", "scanDir", "curl", "POST")) or
    (ProcessCommandLine has_all ("*bitcoin*", "credential", "*recovery*", "curl ")) or
    (ProcessCommandLine has_all ("node", "qemu", "virtual", "parallels", "virtualbox", "vmware", "makelog")) or
    (ProcessCommandLine has_all ("http", "execSync", "userInfo", "windowsHide"))
    and ProcessCommandLine has_any ("socket", "platform", "release", "hostname", "scanDir", "upload"))
)
```

7.2 git hooks 전용 헌팅 (커스텀)

7.2.1 macOS / Linux (bash)

```
# 사용자 home 하위 모든 .git/hooks 디렉터리에서 의심 패턴 검색
find "$HOME" -type d -name "hooks" -path "*/.git/*" 2>/dev/null \
| while read dir; do
    grep -lE "curl |wget |base64 -d|eval |\\$(\\.http" "$dir"/* 2>/dev/null
done
```

7.2.2 osquery

```
SELECT path, sha256, mtime
FROM file
WHERE path LIKE '%/.git/hooks/%'
      AND filename IN ('post-merge', 'post-checkout', 'pre-push', 'post-rewrite',
                        'pre-commit')
      AND size > 100;
```

7.2.3 Splunk

```
index=endpoint sourcetype=osquery
path="*.git/hooks/*"
filename IN ("post-merge", "post-checkout", "pre-push")
| search content="*curl *" OR content="*base64 *" OR content="*wget *"
| stats count by host, path
```

7.3 SIEM 상관 룰 권장

RULE: Contagious Interview Git Hook Trigger
WHEN:
- process = git (clone|pull|merge|checkout)
AND followed by within 30 seconds:
- outbound HTTP/HTTPS to non-organization domain
- by user-context process (not system)
THRESHOLD: 1 occurrence on developer workstation
ACTION: Alert + auto-quarantine cloned directory

8. 방어 권고 (Defense Recommendations)

8.1 개인 개발자 (Individual)

#	조치	명령어 / 설정
1	clone 직후 hooks 검사 습관화	ls -la .git/hooks/ 후 cat post-merge post-checkout pre-push 2>/dev/null
2	글로벌 hook 경로 무력화	mkdir -p ~/.config/git/hooks && git config --global core.hooksPath ~/.config/git/hooks
3	격리 환경에서만 평가 코드 실행	docker run --rm -it --network none ubuntu:24.04 bash (네트워크 차단 컨테이너)
4	npm 자동 스크립트 차단	npm config set ignore-scripts true (글로벌

# 조치	명령어 / 설정
	default)
5 pip 의존성 격리	pip install --no-deps <pkg> 또는 pipx-venv 강제
6 리크루터·회사 검증 5 분 룰	WHOIS 도메인 등록일, LinkedIn 직원 history 확인, 채용공고 회사 공식 사이트 일치 여부
7 하드웨어 키 (YubiKey 등) 의존	자격증명 탈취되어도 2FA 우회 불가
8 암호화폐 시드는 워크스테이션에서 영구 분리	콜드월렛(Ledger, Trezor)만 사용, hot key 는 임시 거래용으로 한정

8.2 조직 (Enterprise)

# 조치	책임 부서
1 전사 Git 클라이언트 정책: core.hooksPath 기본값을 회사 관리 디렉터리로 강제 (MDM·도메인 정책)	IT / SecOps
2 개발자 워크스테이션을 단일 사용 BYOD 분리 — 회사 자산과 개인 freelance 활동 분리 의무화	HR + IT
3 EDR 정책에 본 보고서 §7 KQL-osquery 를 배포	SecOps
4 신규 입사 개발자 OPSEC 교육 모듈 의무 — Contagious Interview·SCARCRUFT·MCP 변종 통합 교육	InfoSec / HR
5 DAXA 거래소·Web3 발행사: deploy 키·멀티시그 시드 보관 워크스테이션을 일반 개발 환경과 물리적·논리적으로 완전 분리 (HSM 또는 air-gap)	CISO / Treasury
6 사내 GitLab/GitHub Enterprise: 외부에서 가져온 ZIP·tarball 자동 스캔 (.git/hooks/ 내용 검사 룰 포함)	DevSecOps

8.3 한국 거래소·Web3 특화 권고

영역	권고
DAXA 차원	회원사 보안 점검 항목에 “개발자 워크스테이션의 git hooks 검사” 의무 항목 추가 검토
거래소 핫월렛 운영	멀티시그 서명 워크스테이션은 인터넷 차단 , USB 차단, 별도 키체인 필수
Web3 발행사	smart contract deploy 키는 별도 air-gap 머신에서만 사용. 일반 개발용 LinkedIn 활동 머신과 절대 공유 금지
프리랜서 채용 시	외부 프리랜서 신원 검증 프로세스 강화. 코드 PR 받기 전에 격리 환경에서 1 차 실행·검증하는 단계 의무화
신규 입사 / 면접 단계	입사 전 사전 보안 브리핑에 “당신을 노린 가짜 리크루터가 LinkedIn 에 있을 수 있다”는 경고 포함

8.4 정책·제도 권고

1. **KISA·NIS·KoFIU 공동 경보 발령 검토** — 거래소·Web3·금융권 개발자 대상 정기 캠페인.
2. **DAXA 자율규제 가이드라인 갱신** — 거래소 등재(listing) 검토 항목에 “발행사 deploy 키 관리 환경 분리 여부” 추가.
3. **국방·방산 협력사 LinkedIn 활동 가이드** — 보안 등급 보유 개발자의 외부 채용 플랫폼 활용에 관한 명시적 정책.
4. **LinkedIn 한국 지사 협력** — DPRK 추정 가짜 리크루터 프로필 신고 채널 강화 및 프로액티브 takedown.

9. MITRE ATT&CK 매핑

Tactic	Technique	ID	본 캠페인에서의 적용
Reconnaissance	Gather Victim Identity Information	T1589	LinkedIn 프로필 스크래핑, 채용 정보 수집
Resource Development	Establish Accounts	T1585	가짜 리크루터·가짜 회사 LinkedIn 계정
Resource Development	Acquire Infrastructure: Domains	T1583.001	신규 회사 도메인 등록 (수주~수개월)
Initial Access	Phishing: Spearphishing via Service	T1566.003	LinkedIn DM·이메일 통한 채용 위장
Initial Access	Trusted Relationship	T1199	채용 절차의 신뢰 관계 악용
Execution	User Execution: Malicious File	T1204.002	표적이 직접 git clone 후 일상 명령 실행
Execution	Event Triggered Execution: Component Object Model Hijacking → Git Hooks (변형)	T1546 (군집)	본 캠페인의 핵심 신규 기법
Persistence	Boot or Logon Autostart Execution	T1547	LaunchAgent / Run 키 / cron
Defense Evasion	Hide Artifacts: Hidden Files and Directories	T1564.001	.git/hooks/는 일반 GUI 에서 미노출
Defense Evasion	Virtualization/Sandbox Evasion	T1497	qemu-vmware 키워드 검사
Credential Access	Credentials from Password Stores: Credentials from Web Browsers	T1555.003	Chrome-Brave-Firefox 자격증명
Credential Access	Credentials from Password Stores: Keychain	T1555.001	macOS Keychain
Collection	Data from Local System	T1005	암호화폐 지갑·SSH 키
Command and Control	Application Layer Protocol: Web Protocols	T1071.001	HTTP POST exfil
Exfiltration	Exfiltration Over C2 Channel	T1041	C2 IP 또는 도메인

MITRE Group ID: G1052 (Contagious Interview) —
<https://attack.mitre.org/groups/G1052>

10. 결론 (Bottom Line)

10.1 한 줄 요약

Lazarus 는 npm 을 막혔더니 화상회의 도구로, 화상회의를 막혔더니 VS Code Tasks 로, VS Code Tasks 가 막혔더니 git hooks 로 옮겨갔다. 다음 진화는 6 개월 안에 온다.

10.2 본 캠페인이 한국 보안 환경에 던지는 질문 세 가지

1. 개발자의 가드가 가장 내려가는 순간이 채용 과정이다. 우리 조직은 그 순간을 보호하고 있는가?
2. .git/hooks/가 사각지대인 것처럼, 우리 워크스테이션에는 코드 리뷰가 닿지 않는 다른 사각지대가 어디에 또 있는가? (다음 표적은 .gitattributes filter? .npmrc prepare? .devcontainer/? Makefile?)
3. Lazarus 가 노리는 건 단일 개발자 한 명의 머신이 아니라, 그 사람을 입구로 한 한국 거래소·Web3 발행사·방산 협력사의 자산이다. 우리는 한 명의 개발자를 잃었을 때의 blast radius 를 측정해 본 적이 있는가?

10.3 단일 강력 권고 (One Mandatory Action)

오늘부터 모든 개발자 워크스테이션에서 다음 한 줄을 실행하라:

```
mkdir -p ~/.config/git/hooks && git config --global core.hooksPath ~/.config/git/hooks
```

이 한 줄이 본 캠페인의 git hooks 변종을 **개인 차원에서 즉시 무력화**한다. 비용 0 원, 시간 30 초. 조직 차원에서는 MDM·도메인 정책으로 강제 배포가 가능하다.

11. 참고 자료 (References)

#	출처	발행	비고
1	OpenSourceMalware.com, "Lazarus Group Uses Git Hooks To Hide Malware"	2026-05	본 보고서의 1 차 분석 대상
2	Matteo Bisi, "Lazarus Group Hides Malware in Git Hooks to Target Developers" (msbiro.net)	2026-05-06	2 차 해설

#	출처	발행	비고
3	Microsoft Security Blog, "Contagious Interview: Malware delivered through fake developer job interviews"	2026-03-11	KQL 룰 제공
4	Abstract Security, "Contagious Interview: Evolution of VS Code and Cursor Tasks Infection Chains Part 2"	2026-03	C2 IP 공개
5	OpenSourceMalware, "Contagious Interview campaign abuses Microsoft VSCode tasks"	2025-11-28	직전 변종
6	NVISO Labs, "Contagious Interview Actors Now Utilize JSON Storage Services for Malware Delivery"	2025-11-13	도구 계보
7	Cisco Talos, "BeaverTail and OtterCookie evolve with a new Javascript module"	2025-10-16	도구 분석
8	Socket, "North Korea's Contagious Interview Campaign Escalates: 338 Malicious npm Packages, 50,000 Downloads"	2025-10-10	규모
9	Socket, "Another Wave: 35 New Malicious npm Packages"	2025-06-24	npm 진화
10	ANY.RUN, "OtterCookie: Analysis of Lazarus Group Malware Targeting Finance and Tech Professionals"	2025-06-03	표적 분석
11	ESET Research, "ESET APT Activity Report Q4 2024-Q1 2025"	2025-05-12	그룹 활동
12	NTT Security, "Additional Features of OtterCookie Malware Used by WaterPlum"	2025-05-07	변종 분석
13	HiSolutions, "Rolling in the Deep(Web): Lazarus Tsunami"	2025-04-25	TsunamiKit
14	Silent Push, "Contagious Interview Launches a New Campaign Creating Three Front Companies"	2025-04-24	인프라
15	MITRE ATT&CK, Group G1052	지속 갱신	표준 트래커
16	Malpedia, py.invisibleferret	지속 갱신	도구 카탈로그

End of Report — CTI-2026-0510-LAZARUS-GITHOOKS — TLP:GREEN

· 2026-05-10 © 2026 Dennis Kim (김호광) · gameworker@gmail.com ·

<https://github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT>

*"Lazarus 는 한 통로를 막을 때마다 6 개월 안에 더 깊은 곳으로 옮겨간다. 다음
사각지대는 어디인가?" — CTI-2026-0510-LAZARUS-GITHOOKS*